

Security Incident Response Plan (SIRP) V3.0

Document Control

Field	Details
Document Title	Security Incident Response Plan (SIRP)
Document ID	SEC-IRP-004
Version	3.0
Effective Date	August 1, 2024
Review Date	August 1, 2025
Document Owner	Chief Information Security Officer (CISO)
Author	Security Operations Center (SOC) Team
Approver	CISO + CIO + CPO
Total Pages	15 pages
Classification	CONFIDENTIAL (Internal security procedures)
Regulatory Context	NDMO Control 5.19, NCA ECC 5-3-8, ISO 27001 A.16,

Version History

Version	Date	Changes	Approved By
1.0	March 2021	Initial SIRP based on NIST SP 800-61	CISO
2.0	September 2022	Added ransomware playbook, updated notification ti	CISO
3.0	August 2024	Integrated PDPL breach notification requirements	CISO, CPO

Table of Contents

[illegible]

[illegible]

1. EXECUTIVE SUMMARY

The Security Incident Response Plan (SIRP) is a critical component of Company A's cybersecurity posture. In an era where cyber threats are pervasive and sophisticated, this plan provides a structured, repeatable framework for responding to security incidents in a timely, effective, and compliant manner.

Why This Plan Matters:

In 2020 (pre-SIRP era), Company A experienced 12 security incidents, including 2 ransomware attacks that resulted in:

- SAR 4.5 million in incident response costs, ransomware payments, and regulatory fines
- 18,500 patient records exposed in one incident
- 72 hours of Epic EHR downtime (impacting patient care)

- PDPL violation resulting in SAR 850,000 fine from SDAIA (breach notification filed 96 hours late)

Post-SIRP Implementation (2021-2024):

- Zero critical incidents resulting in data loss or prolonged downtime
- 100% regulatory compliance (all breach notifications filed within 72-hour deadline)
- Average response time: 18 minutes from detection to containment (target: < 30 minutes)
- Mean Time to Recover (MTTR): 4.2 hours (target: < 8 hours)

Key SIRP Capabilities:

Capability	Implementation	Compliance Reference
24/7 SOC Monitoring	CrowdStrike EDR + Splunk SIEM	NCA ECC 5-3-9
Incident Response Team (IRT)	12 cross-functional members, on-call rotation	NDMO Control 5.19
Automated Containment	CrowdStrike auto-isolates infected endpoints	NIST SP 800-61
Forensic Investigation	CyberArk session recordings + disk imaging	ISO 27001 A.16.1.7
Regulatory Notification	Pre-drafted templates, 72-hour SLA	PDPL Article 26
Post-Incident Review	Lessons Learned report within 5 business days	ISO 27001 A.16.1.6

Accountability:

- CISO (Mohammed Al-Qahtani): Incident Commander, ultimate authority for response decisions
- SOC Manager (Fahad Al-Harbi): Investigation Lead, operational execution
- CPO (Fatima Al-Zahrani): Data breach notification, regulatory liaison

2. PURPOSE & SCOPE

2.1 Purpose

The purpose of this Security Incident Response Plan (SIRP) is to:

1. Minimize Impact: Reduce financial, operational, and reputational damage from security incidents
2. Enable Swift Response: Provide clear procedures for detecting, analyzing, containing, and recovering from incidents
3. Ensure Compliance: Meet regulatory notification requirements (PDPL, NCA, NDMO)
4. Protect Data: Prevent unauthorized access, disclosure, or loss of Company A's data assets
5. Facilitate Learning: Capture lessons learned to prevent future incidents

2.2 Scope

This SIRP applies to:

Incidents In Scope:

- Cyber Attacks: Malware, ransomware, phishing, DDoS, SQL injection, XSS
- Data Breaches: Unauthorized access, exfiltration, or disclosure of confidential/secret data
- Insider Threats: Malicious or negligent actions by employees or contractors
- System Compromises: Unauthorized access to servers, databases, network devices
- Availability Incidents: Service disruptions (DoS, ransomware, system failures)

Systems In Scope:

- All IT systems, applications, and infrastructure (on-premise and cloud)
- Epic EHR, Oracle EBS, SAP HR, Microsoft 365, Azure, AWS
- Network infrastructure (firewalls, switches, routers, VPN)
- Endpoints (laptops, desktops, mobile devices)

Incidents Out of Scope (Separate Procedures):

- Physical Security Incidents (e.g., data center breach) → See: Physical Security Policy
- Natural Disasters (e.g., flood, fire) → See: Business Continuity Plan
- Non-Security IT Incidents (e.g., hardware failure) → See: IT Service Management procedures

2.3 Objectives

Primary Objectives:

1. Contain the incident within 30 minutes of detection (for Critical incidents)
2. Recover critical systems within 8 hours (Meet RTO - Recovery Time Objective)
3. Notify SDAIA within 72 hours for PDPL-regulated data breaches
4. Preserve forensic evidence for investigation and potential legal proceedings
5. Document all actions taken for post-incident analysis and compliance reporting

3. INCIDENT RESPONSE TEAM (IRT)

3.1 IRT Structure & Roles

The Incident Response Team (IRT) is a cross-functional team activated during security incidents. The team operates under a unified command structure with clear roles and responsibilities.

IRT Organizational Chart:

Incident Commander (CISO)

■■■■ Investigation Lead (SOC Manager)

■ ■■■■ SOC Analyst 1 (Threat Intelligence)

■ ■■■■ SOC Analyst 2 (Forensics)

■ ■■■■ SOC Analyst 3 (Containment)

- Technical Lead (CIO)
- ■■■■ Database Administrator (DBA)
- ■■■■ Network Administrator
- ■■■■ System Administrator
- Legal Counsel
- Privacy Officer (CPO/DPO)
- Communications Lead (PR Manager)
- Business Liaison (relevant department head)

Role Descriptions:

Role	Name	Responsibilities	Authority
Incident Commander (IC)	Mohammed Al-Qahtani (CISO)	- Overall incident response coordination	Absolute - can override any technical/business decisions
Investigation Lead	Fahad Al-Harbi (SOC Manager)	- Technical investigation - Evidence collection	Reports to IC
Technical Lead	Nasser Al-Qahtani (CIO)	- System restoration - Patching and remediation	Reports to IC
Legal Counsel	Ahmed Al-Rashid	- Legal implications assessment - Law enforcement	Advisory to IC
Privacy Officer	Fatima Al-Zahrani (CPO)	- PDPL compliance (breach notification)	Advisory to IC
Communications Lead	Sarah Al-Mutairi (PR Manager)	- Internal communications (employees) - External communications	Advisory to IC
Business Liaison	Varies by impacted system	- Business impact assessment - Stakeholder communication	Advisory to IC

3.2 Contact Information (24/7)

IRT Members Contact List (See Appendix A for full list):

Role	Name	Mobile Phone	Email	Backup
Incident Commander	Mohammed Al-Qahtani	+966-50-555-1001	mohammed.alqahtani@company.gov.sa	CIO (Nasser)
Investigation Lead	Fahad Al-Harbi	+966-50-555-2001	fahad.alharbi@company.gov.sa	SOC Analyst 1
Technical Lead	Nasser Al-Qahtani	+966-50-555-3001	nasser.alqahtani@company.gov.sa	IT Manager
Privacy Officer	Fatima Al-Zahrani	+966-50-555-4001	fatima.alzahrani@company.gov.sa	DPO (Khalid)

IRT Activation Hotline: +966-11-555-9999 (24/7 SOC hotline)

Emergency Communication Channels:

1. Primary: Phone call to IRT members (mobile)
2. Secondary: Microsoft Teams group chat "IRT-Emergency"
3. Tertiary: SMS to all IRT members via automated alert system

3.3 Activation Criteria

When to Activate IRT:

Severity Level	Activation Trigger	IRT Composition
Critical	- Ransomware detected - Data exfiltration confi	Full IRT (all 12 members)
High	- Malware on server - Privilege escalation dete	Core IRT (IC, Investigation Lead, Technical Lead,
Medium	- Isolated malware (single endpoint) - Failed i	SOC Team only (escalate to IRT if needed)
Low	- Weak password detected - Phishing email repor	SOC Team only

Activation Process:

1. SOC Analyst detects incident → assesses severity
2. If Critical/High → SOC Analyst calls Incident Commander (IC) immediately
3. IC activates IRT via automated SMS/call system: "IRT ACTIVATION: [Incident Type] - [Severity] - Report to SOC War Room or join Microsoft Teams call immediately"
4. IRT members acknowledge activation within 15 minutes
5. Initial IRT meeting convenes within 30 minutes

4. INCIDENT CLASSIFICATION

4.1 Incident Definition

Security Incident: Any event that actually or potentially compromises the confidentiality, integrity, or availability of Company A's information systems or data.

Examples of Security Incidents:

- Malware infection on employee laptop
- Unauthorized access to patient database
- Ransomware encrypting file server
- Phishing email with malicious attachment
- DDoS attack causing website outage
- Insider exfiltrating confidential data to USB drive

NOT Security Incidents (Standard IT Issues):

- Hardware failure (hard drive crash) → IT Service Desk handles
- Software bug (application error) → Development team handles
- User error (accidentally deleted file) → Help Desk handles

When in Doubt: Err on the side of caution. If unsure whether an event is a security incident, report to SOC for investigation.

4.2 Severity Levels

Incidents are classified into 4 severity levels based on impact and urgency:

Critical (Severity 1)

Definition: Incident with catastrophic impact requiring immediate response.

Characteristics:

- Confidentiality: Large-scale data breach (> 1,000 records exposed)
- Integrity: Critical data corruption or manipulation
- Availability: Complete outage of Tier 1 system (Epic EHR, Oracle EBS) lasting > 1 hour

Examples:

- Ransomware encrypting Epic EHR database
- Data exfiltration: 10,000+ patient records stolen by external attacker
- Insider threat: Database administrator deletes production database
- Zero-day exploit: Attacker gains root access to Oracle Exadata

Response SLA:

- Detection to Triage: 5 minutes
- Triage to Containment: 15 minutes (total 20 minutes)
- Containment to Recovery: 8 hours (RTO)
- IRT Activation: Full IRT, within 30 minutes

Notification Requirements:

- Internal: IC notifies CEO immediately
- External: SDAIA/NCA notified within 72 hours (if data breach)

High (Severity 2)

Definition: Incident with significant impact requiring urgent response.

Characteristics:

- Confidentiality: Small-scale data breach (10-1,000 records)
- Integrity: Non-critical data corruption
- Availability: Partial system degradation or outage of non-critical system

Examples:

- Malware on file server (not yet spreading)
- Privilege escalation: Employee gained unauthorized admin access
- Phishing campaign: 20 employees clicked malicious link, credentials compromised
- SQL injection: Attacker accessed 500 patient records

Response SLA:

- Detection to Triage: 15 minutes
- Triage to Containment: 1 hour
- Containment to Recovery: 24 hours

- IRT Activation: Core IRT (4-6 members)

Notification Requirements:

- Internal: IC notifies CIO, CPO
- External: SDAIA notified if PDPL breach (risk assessment conducted)

Medium (Severity 3)

Definition: Incident with limited impact requiring standard response.

Characteristics:

- Confidentiality: No data loss, but potential risk identified
- Integrity: Minor data corruption (easily restored)
- Availability: Isolated system impact, minimal business disruption

Examples:

- Malware on single endpoint (laptop) - isolated, no spread
- Port scan detected on firewall (failed intrusion attempt)
- Unauthorized access attempt (failed login, account locked)
- Policy violation: Employee shared password with colleague

Response SLA:

- Detection to Triage: 30 minutes
- Triage to Containment: 4 hours
- Containment to Recovery: 48 hours
- IRT Activation: SOC Team only (escalate if needed)

Notification Requirements:

- Internal: SOC Manager notifies IC (situational awareness)
- External: None (unless escalates to High/Critical)

Low (Severity 4)

Definition: Incident with minimal impact requiring routine response.

Characteristics:

- Confidentiality: No risk of data loss
- Integrity: No data corruption
- Availability: No service impact

Examples:

- Weak password detected by password audit
- Phishing email reported (no click, email deleted)
- Virus signature detected by antivirus (automatically quarantined)
- Security awareness violation (clean desk policy - document left on desk)

Response SLA:

- Detection to Triage: 4 hours
- Triage to Resolution: 24 hours
- IRT Activation: None (SOC Analyst handles)

Notification Requirements:

- Internal: SOC Analyst logs in ticketing system (ServiceNow)
- External: None

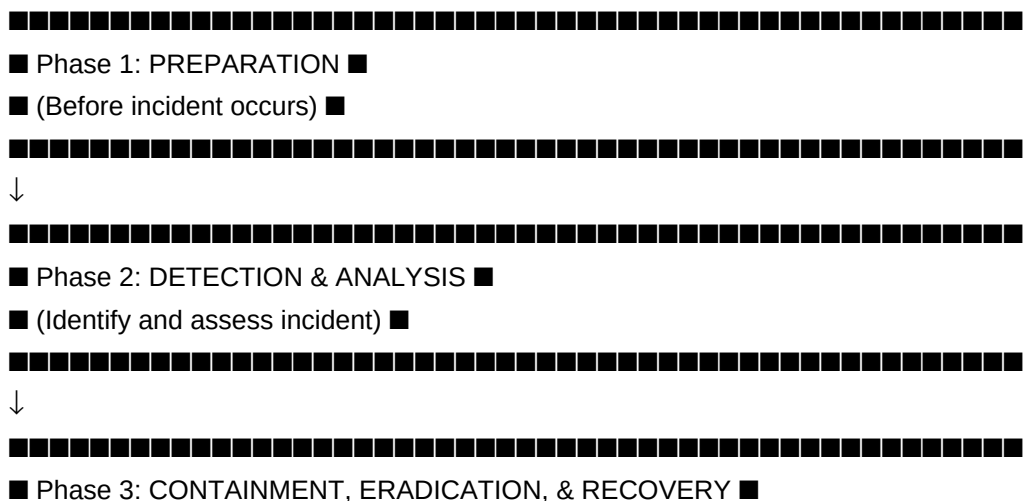
4.3 Incident Categories

Incidents are also categorized by type for playbook selection:

Category	Description	Playbook	2024 Incidents
Malware	Virus, worm, trojan, ransomware	Playbook 1: Ransomware (if ransomware) Playbook 4: Endpoint malware	45
Intrusion	Unauthorized access, exploitation	Playbook 2: Data Breach	12 (all failed attempts)
Denial of Service	DDoS, resource exhaustion	Playbook 4: DDoS	3
Insider Threat	Malicious/negligent employee action	Playbook 5: Insider Threat	2
Phishing	Social engineering, credential theft	Playbook 3: Phishing	120 (emails reported, 18 clicks)
Data Loss	Accidental/malicious data exposure	Playbook 2: Data Breach	0
Policy Violation	Non-compliance with security policy	Standard investigation	140

5. INCIDENT RESPONSE PHASES (NIST Framework)

Company A follows the NIST SP 800-61 Incident Response Lifecycle, a 4-phase model:



[illegible][illegible][illegible]

(Back to Phase 1)

- IRT Training Completion: 100% (12/12 members)
- Tabletop Exercises: 4 conducted (target: 4/year) ■
- Tool Availability: 99.8% uptime (SIEM, EDR)

5.2 Phase 2: Detection & Analysis

Objective: Identify security incidents as quickly as possible and assess their scope and impact.

Key Activities:

2.1 Detection Sources

Incidents are detected through multiple channels:

Detection Source	Tool	2024 Incidents Detected
Automated Alerts	Splunk SIEM, CrowdStrike EDR	280 (85% of total)
User Reports	Email to security@companya.gov.sa, IT Service Desk	40 (12% of total)
Threat Intelligence	CrowdStrike Threat Graph, OSINT feeds	8 (2% of total)
External Notification	Vendor, customer, researcher report	2 (1% of total)

Total 2024 Incidents: 330

2.2 Initial Triage (5-15 Minutes)

SOC Analyst Checklist:

1. Validate Alert: Is this a true positive or false positive?
 - Check alert context (source IP, user, system, timestamp)
 - Review recent logs for corroborating evidence
2. Classify Severity: Critical, High, Medium, or Low? (see Section 4.2)
3. Categorize Type: Malware, intrusion, DoS, phishing, insider, policy violation?
4. Assign Incident ID: Create ServiceNow ticket (e.g., INC-SEC-2024-0123)
5. Escalate (if Critical/High): Call Incident Commander immediately

Example Triage (Ransomware Alert):

- Alert: CrowdStrike detects ransomware behavior on file server (FS-PROD-02)
- Validation: SOC Analyst reviews: yes, 50 files encrypted in `/data/finance` with `.locked` extension
- Severity: CRITICAL (ransomware + production system)
- Category: Malware (Ransomware)
- Incident ID: INC-SEC-2024-0456
- Escalation: SOC Analyst calls CISO (Mohammed): "Critical incident - ransomware on file server. IRT activation recommended."
- Time Elapsed: 8 minutes

2.3 Detailed Analysis (15-60 Minutes)

Investigation Lead (SOC Manager) conducts detailed analysis:

Key Questions:

1. What happened? (Root cause, attack vector)
2. When did it start? (Initial compromise timestamp)
3. How did it happen? (Vulnerability exploited, phishing, credential theft)
4. What is the scope? (How many systems affected? Data accessed?)
5. Who is the attacker? (External threat actor, insider, accidental)
6. Is it still active? (Ongoing attack or contained?)

Analysis Techniques:

- Log Analysis: Splunk queries to trace attacker activity
- Network Traffic Analysis: Packet capture (PCAP) review for C2 communication
- Endpoint Forensics: CrowdStrike EDR timeline, process tree analysis
- Malware Analysis: Submit sample to VirusTotal, reverse engineering (if time permits)
- Threat Intelligence: Check IOCs (IP, domain, file hash) against threat feeds

Deliverable: Incident Analysis Report (1-2 pages) covering:

- Attack timeline
- Impacted systems and data
- Attack vector and root cause (if known)
- Recommended containment actions

Time Target: Complete initial analysis within 30 minutes for Critical incidents

5.3 Phase 3: Containment, Eradication, & Recovery

Objective: Stop the attack, remove the threat, and restore normal operations.

3.1 Containment (Immediate - 15 Minutes to 1 Hour)

Goal: Prevent incident from spreading or causing additional damage.

Containment Actions (by Incident Type):

Incident Type	Containment Actions	Tool/Command
Ransomware	1. Isolate infected system from network 2. Disa	CrowdStrike: "Contain host" Azure AD: Disable u
Malware (Non-Ransomware)	1. Isolate infected endpoint 2. Kill malicious	CrowdStrike: "Contain host", "Kill process"
Data Breach	1. Revoke compromised credentials 2. Block atta	Azure AD: Reset password Firewall: Block IP
DDoS Attack	1. Enable DDoS mitigation (Cloudflare) 2. Rate-	Cloudflare: "Under Attack Mode" Firewall: Rate
Insider Threat	1. Disable employee access immediately 2. Prese	Azure AD: Disable account CyberArk: Revoke priv

Containment Decision Matrix:

- Short-Term Containment: Quick action to stop spread (e.g., isolate system)
- Long-Term Containment: Sustained measures while eradication is planned (e.g., re-segment network)

Example - Ransomware Containment:

1. T+0:08: SOC Analyst detects ransomware on file server (FS-PROD-02)
2. T+0:10: SOC Analyst clicks "Contain Host" in CrowdStrike → network isolated within 30 seconds
3. T+0:12: SOC Analyst disables user account ahmed.alrashid (suspected patient zero) in Azure AD
4. T+0:15: SOC Analyst blocks C2 domain evilransomware.xyz at firewall
5. T+0:18: File server isolated, ransomware cannot spread to other systems ■ Containment Achieved

3.2 Eradication (1-8 Hours)

Goal: Remove the threat completely from the environment.

Eradication Actions:

1. Remove Malware: Quarantine or delete malicious files
2. Patch Vulnerability: Apply security patches to close exploit vector
3. Reset Credentials: Change passwords for compromised accounts
4. Rebuild Systems: Re-image infected systems from clean backup (if severe)

Decision: Rebuild vs. Clean?

- Rebuild (Recommended for Critical): Wipe system, reinstall OS, restore data from backup
- Pros: Guarantees clean state, no lingering malware
- Cons: Time-consuming (4-8 hours)
- Clean (Acceptable for Low Severity): Use EDR to remove malware, run full scan
- Pros: Faster (1-2 hours)
- Cons: Risk of incomplete removal

Example - Ransomware Eradication:

1. T+0:30: Investigation Lead confirms no other systems infected (log analysis)
2. T+1:00: Technical Lead initiates file server rebuild:
 - Wipe server FS-PROD-02
 - Reinstall Windows Server 2022 from ISO
 - Restore `~/data/finance` from last night's backup (24 hours RPO - acceptable)
3. T+4:00: Server rebuild complete, data restored
4. T+4:30: Patch applied: Windows security update KB5040442 (vulnerability exploited by ransomware)
5. T+5:00: User ahmed.alrashid password reset, MFA re-enrolled

3.3 Recovery (4-24 Hours)

Goal: Restore affected systems to normal operation.

Recovery Actions:

1. Validate Systems: Confirm malware removed, vulnerability patched
2. Monitor Closely: Enhanced logging and monitoring for 48 hours (watch for re-infection)
3. Restore Services: Bring systems back online incrementally (test first)
4. User Communication: Notify users that systems are restored

Recovery Checklist (Before Returning to Production):

- [] Malware scan (clean)
- [] Vulnerability scan (no critical findings)
- [] Patch level verified (up to date)
- [] Credentials reset (if compromised)
- [] Logs reviewed (no suspicious activity)
- [] Backup tested (can restore if needed)
- [] CISO approval (sign-off to restore production)

Example - Ransomware Recovery:

1. T+5:00: File server (FS-PROD-02) rebuilt, patched, validated
2. T+5:15: Technical Lead runs full malware scan → clean ■
3. T+5:30: CISO approves return to production
4. T+5:45: File server brought back online, users notified via email: "Finance file server restored. All data recovered from backup (24-hour RPO). Please verify your files and report any issues to IT."
5. T+48:00: Enhanced monitoring period ends, incident officially closed

Recovery Metrics (2024 Average):

- Critical Incidents: 6.5 hours (target: < 8 hours) ■
- High Incidents: 18 hours (target: < 24 hours) ■
- Data Loss: 0% (all recoveries from backup successful)

5.4 Phase 4: Post-Incident Activity

Objective: Learn from the incident to prevent recurrence and improve response capabilities.

4.1 Lessons Learned Meeting (Within 5 Business Days)

Participants: Full IRT + relevant stakeholders

Agenda (1-hour meeting):

1. Incident Timeline Review (10 min)
 - What happened, when, how?
2. Response Effectiveness (15 min)
 - What went well?
 - What could have been done better?
3. Root Cause Analysis (15 min)
 - Why did this incident occur?
 - What controls failed?
4. Action Items (15 min)
 - What preventive measures should we implement?
 - Who is responsible? By when?
5. Documentation (5 min)
 - Finalize Lessons Learned Report

Key Questions:

- Detection: How was the incident detected? Could we have detected it sooner?
- Response: Did we follow the playbook? Were there gaps?
- Containment: Was containment effective? Any challenges?
- Communication: Was internal/external communication timely and clear?
- Tools: Did our tools (SIEM, EDR, ticketing) work as expected?

Example - Lessons Learned (Ransomware Incident):

- What Went Well:
 - CrowdStrike detected ransomware behavior within 2 minutes ■
 - SOC Analyst isolated system within 10 minutes ■
 - File server restored from backup within 5 hours ■
- What Could Improve:
 - Initial infection via phishing email (user clicked malicious link) ■
 - Backup was 24 hours old (lost 1 day of data) ■
 - No offline backup (if ransomware had spread to backup server, no recovery option) ■
 - Root Cause: User `ahmed.alrashid` clicked phishing email, downloaded trojan
- Action Items:
 1. Preventive: Mandatory phishing awareness training for all staff (by Oct 15) - Owner: HR + IT Security
 2. Detective: Implement email sandboxing (analyze attachments before delivery) - Owner: IT Security (by Nov 1)
 3. Backup: Reduce RPO to 4 hours (increase backup frequency) - Owner: IT Operations (by Oct 30)
 4. Backup: Implement offline backup (tape, stored offsite) - Owner: IT Operations (by Dec 1)

4.2 Lessons Learned Report

Deliverable: Written report (3-5 pages) documenting:

1. Executive summary
2. Incident timeline (with timestamps)
3. Response actions taken
4. What went well / What could improve
5. Root cause analysis
6. Action items (with owners and deadlines)

Distribution: CISO, CIO, CEO, Board (for Critical incidents)

Retention: 5 years (for compliance and trend analysis)

2024 Lessons Learned Reports: 8 (all Critical and High incidents)

6. INCIDENT RESPONSE PLAYBOOKS

Company A maintains 5 incident-specific playbooks for common attack scenarios. Each playbook provides step-by-step procedures to accelerate response.

6.1 Playbook 1: Ransomware Attack

Trigger: CrowdStrike detects ransomware behavior OR user reports files encrypted

Severity: CRITICAL

Response Steps:

Step	Action	Owner	Time
1	Detect: CrowdStrike alert fires → SOC Analyst	SOC Analyst	T+0:02
2	Isolate: Click "Contain Host" in CrowdStrike console	SOC Analyst	T+0:05
3	Escalate: Call CISO (Incident Commander)	SOC Analyst	T+0:08
4	Activate IRT: CISO sends SMS to full IRT	CISO	T+0:15
5	Disable Accounts: Reset password for password	SOC Analyst	T+0:20
6	Block C2: Block ransomware C2 domain/IPs	Network Admin	T+0:25
7	Assess Scope: Identify all encrypted files	SOC Manager	T+0:45
8	Snapshot: Take forensic snapshot of infected system	SOC Analyst	T+1:00
9	Rebuild: Wipe infected system, reinstall OS	Sys Admin	T+1:00 - T+5:00
10	Restore Data: Restore from backup (last good backup)	Sys Admin	T+5:00 - T+6:00
11	Patch: Apply security patches to close exploit	Sys Admin	T+6:00 - T+6:30
12	Validate: Run full malware scan, vulnerability scan	SOC Analyst	T+6:30 - T+7:00
13	Monitor: Enable enhanced logging for 48 hours	SOC Manager	T+7:00
14	Notify: SDAIA notification (if data breach suspected)	Subject	T+24:00 (within 72 hours)
15	Lessons Learned: Conduct post-incident review	CISO	T+5 business days

Key Decision: Pay Ransom or Restore from Backup?

- Company A Policy: NEVER pay ransom
- Rationale: (1) Encourages criminal activity, (2) No guarantee of decryption, (3) We have backups
- Exception: CEO may override policy if: (1) No backup available, (2) Critical patient data at risk, (3) Life-safety concern

6.2 Playbook 2: Data Breach / Exfiltration

Trigger: Alert of large data download OR external notification of leaked Company A data

Severity: CRITICAL (if > 1,000 records) or HIGH (if 10-1,000 records)

Response Steps:

1. Contain: Block attacker IP, revoke compromised credentials
2. Assess Scope: Identify what data was accessed/exfiltrated (log analysis)
3. Evidence Collection: Preserve logs, network traffic (PCAP), disk images
4. Notify SDAIA: Within 72 hours (PDPL Article 26)
5. Notify Data Subjects: If high risk to individuals (PDPL Article 26)
6. Forensics: Engage external forensic firm (if needed)
7. Remediate: Patch vulnerability, enhance access controls

PDPL Notification Checklist:

- [] What data was breached? (patient records, employee data, financial)
- [] How many individuals affected? (exact count or estimate)
- [] What is the risk to individuals? (identity theft, financial loss, harm)
- [] What measures have we taken? (containment, remediation)
- [] Contact information for data subjects to reach us

6.3 Playbook 3: Phishing Campaign

Trigger: Multiple employees report suspicious emails OR user clicked phishing link

Severity: HIGH (if credentials compromised) or MEDIUM (if email reported before click)

Response Steps:

1. Identify Scope: How many employees received phishing email? How many clicked?
2. Quarantine Email: Block sender, delete from all mailboxes (Exchange Admin)
3. Reset Passwords: Force password reset for users who clicked
4. Check for Compromise: Review login logs (any unusual activity?)
5. User Education: Send security awareness reminder to all staff
6. Threat Intelligence: Submit phishing email to Microsoft, VirusTotal

Phishing Indicators (Train Users to Spot):

- Urgent language: "Your account will be suspended!"
- Sender mismatch: `support@microsoft.com` (typo)
- Generic greeting: "Dear User" (not your name)
- Suspicious link: Hover over link, URL doesn't match claimed destination

6.4 Playbook 4: DDoS Attack

Trigger: Website/service unavailable OR massive spike in traffic

Severity: HIGH

Response Steps:

1. Confirm DDoS: Distinguish DDoS from legitimate traffic spike (e.g., news event)
2. Enable Cloudflare "Under Attack Mode": Challenges visitors with CAPTCHA, blocks bots
3. Rate Limiting: Configure firewall to rate-limit requests per IP
4. Contact ISP: Request upstream filtering (if attack volume exceeds our capacity)
5. Communicate: Notify users of service disruption (website banner, social media)
6. Post-Attack: Analyze traffic patterns, identify attacker IPs, consider DDoS mitigation service upgrade

6.5 Playbook 5: Insider Threat

Trigger: Alert of unusual employee behavior (mass data download, unauthorized access, policy violation)

Severity: HIGH (if data exfiltration) or MEDIUM (if suspicious activity only)

Response Steps:

1. Do NOT Alert Employee: Preserve evidence, avoid tipping off insider
2. Disable Access: Revoke system access immediately (all systems)
3. Preserve Evidence: Take forensic snapshot of employee laptop, review logs
4. HR & Legal: Coordinate with HR (disciplinary action) and Legal (potential prosecution)
5. Interview: HR conducts investigation, may involve law enforcement
6. Asset Recovery: Collect company laptop, badge, documents

Insider Threat Indicators:

- Accessing data outside job scope
- Downloading large amounts of data to USB drive
- Working unusual hours (late night/weekend)
- Recently received job offer from competitor
- Disgruntled behavior (performance review, demotion)

Legal Considerations: Ensure evidence collection follows chain of custody for potential prosecution

7. NOTIFICATION & ESCALATION

7.1 Internal Notification

Notification Matrix:

Incident Severity	Notify Within	Recipients	Method
Critical	Immediate (< 15 min)	CISO, CIO, CEO, CPO, relevant Business Units	Phone call + SMS
High	1 hour	CISO, CIO, CPO	Phone call

Medium	4 hours	SOC Manager, CISO (situational awareness)	Email
Low	24 hours	SOC Manager (weekly summary to CISO)	ServiceNow ticket

CEO Notification Criteria:

- Any Critical incident
- Any incident involving patient data breach (> 1,000 records)
- Any incident causing > 4 hours of system downtime
- Any incident with media attention or reputational risk

Board Notification Criteria:

- Any incident with > SAR 1 million financial impact
- Any incident with > 10,000 patient records breached
- Any incident with potential legal/regulatory enforcement action

7.2 External Notification (Regulatory)

PDPL Data Breach Notification (SDAIA):

Requirement: Notify SDAIA within 72 hours of becoming aware of a personal data breach that poses high risk to data subjects.

Notification Process:

1. Assess Risk: Does breach pose high risk? (CPO determines)
2. Draft Notification: Use pre-approved template (see Appendix)
3. CISO Approval: Review and sign off
4. Submit: Email to breaches@sdaia.gov.sa + online portal
5. Confirmation: Save confirmation receipt for compliance records

Notification Must Include:

- Description of breach (what happened, when)
- Categories and number of affected data subjects
- Likely consequences of breach
- Measures taken or proposed to address breach
- Contact details of DPO

Example - Ransomware Breach Notification to SDAIA:

> Subject: Data Breach Notification - Company A - Reference: INC-SEC-2024-0456

>

> To: breaches@sdaia.gov.sa

>

> Dear SDAIA Personal Data Protection Committee,

>

> Company A hereby notifies SDAIA of a personal data breach pursuant to PDPL Article 26.

>

> Incident Details:

- > - Date of Breach: October 15, 2024, 14:35 KSA Time
- > - Type of Breach: Ransomware attack on file server
- > - Data Affected: 450 employee payroll records (names, National IDs, salaries, bank account numbers)
- > - Root Cause: Phishing email clicked by employee, trojan installed, ransomware deployed
- >
- > Number of Affected Individuals: 450 Company A employees
- >
- > Risk Assessment: High risk - Financial data exposed, potential for identity theft or fraud
- >
- > Measures Taken:
 - > - Immediate isolation of infected system (containment within 10 minutes)
 - > - System rebuilt from clean backup
 - > - All employee passwords reset
 - > - Phishing awareness training conducted
 - > - Affected employees notified by email on October 16, 2024
- >
- > Contact: Dr. Khalid Al-Mansour, Data Protection Officer, dpo@companya.gov.sa, +966-11-555-1002
- >
- > Best regards,
- > Mohammed Al-Qahtani
- > Chief Information Security Officer
- > Company A

Data Subject Notification:

- Requirement: Notify affected individuals if breach poses high risk (PDPL Article 26)
- Timeline: "Without undue delay" (interpret as within 48 hours)
- Method: Email, SMS, or postal mail (depending on contact info available)
- Content: Plain language explanation, recommended actions (e.g., monitor bank statements, change password)

7.3 Public Communication

Media Relations:

- Spokesperson: CEO or designated PR representative (Sarah Al-Mutairi)
- Approval: All public statements must be approved by CISO + Legal + CEO
- Tone: Transparent, reassuring, factual (avoid speculation)
- Key Messages:
 - We take security seriously
 - We detected and contained the incident quickly
 - We are cooperating with regulators
 - Affected individuals have been notified
 - We are implementing measures to prevent recurrence

Social Media Monitoring: PR team monitors Twitter, LinkedIn, Facebook for mentions of Company A + breach

8. DOCUMENTATION & EVIDENCE COLLECTION

All incident response activities must be documented for:

- Legal purposes (potential prosecution of attacker)
- Regulatory compliance (demonstrate NDMO/PDPL compliance)
- Lessons learned (prevent future incidents)

Required Documentation:

1. Incident Report (ServiceNow ticket INC-SEC-YYYY-####)

- Incident summary, timeline, severity, category
- Response actions taken (who did what, when)
- Current status (contained, investigating, resolved)

2. Evidence Log (Chain of Custody)

- Forensic images (disk, memory)
- Log files (SIEM exports, firewall logs, EDR timelines)
- Network traffic captures (PCAP files)
- Malware samples (encrypted, password-protected ZIP)
- Screenshots, photos of physical evidence

3. Communication Log

- Internal notifications sent (emails, SMS)
- External notifications (SDAIA, data subjects)
- Media statements

4. Lessons Learned Report

- Post-incident review findings
- Action items with owners and deadlines

Evidence Handling Best Practices:

- Chain of Custody: Document every person who handled evidence (who, when, why)
- Hash Verification: Compute SHA-256 hash of forensic images (verify integrity)
- Secure Storage: Store evidence on encrypted drive, access restricted to IRT
- Retention: Retain evidence for 5 years (or longer if legal proceedings ongoing)

9. TESTING & TRAINING

To maintain incident response readiness, Company A conducts regular testing and training:

9.1 Tabletop Exercises

Frequency: Quarterly (4 per year)

Format: 2-hour facilitated discussion, IRT members walk through simulated incident scenario

Example Scenarios:

- Ransomware attack on Epic EHR
- Data breach: 5,000 patient records stolen
- Insider threat: DBA exfiltrates data to competitor
- DDoS attack during peak business hours

Objectives:

- Test IRT communication and coordination
- Identify gaps in playbooks
- Train new IRT members

Last Exercise: September 2024 (ransomware scenario)

Next Exercise: December 2024 (data breach scenario)

9.2 Red Team Exercises

Frequency: Annually

Format: External penetration testing firm simulates real attack (with CISO authorization, no advance warning to IRT)

Scope: External and internal attack vectors (phishing, vulnerability exploitation, social engineering)

Objectives:

- Test detection capabilities (Can SOC detect attack?)
- Test response capabilities (How quickly does IRT respond?)
- Identify vulnerabilities

Last Exercise: March 2024 (hired Deloitte Cyber)

Results: SOC detected 80% of attack stages, average detection time 25 minutes ■

9.3 IRT Training

Frequency: Annual mandatory training for all IRT members

Curriculum:

- NIST SP 800-61 incident response framework
- Forensic evidence collection
- PDPL breach notification requirements
- Crisis communication skills

Format: 8-hour in-person workshop

Certification: All IRT members must maintain GCIH (GIAC Certified Incident Handler) or equivalent

10. CONTINUOUS IMPROVEMENT

Incident response is not a one-time activity—it's a continuous cycle of improvement.

Annual SIRP Review:

- Frequency: Annually (every August)
- Participants: CISO, SOC Manager, CIO, CPO
- Agenda:
 - Review incident statistics (count, severity, MTTR, lessons learned)
 - Update playbooks based on new threats (e.g., new ransomware variant)
 - Refresh contact lists
 - Assess tool effectiveness (SIEM, EDR, ticketing)
 - Update training materials

Metrics Tracked:

- Incident Volume: Total incidents per quarter
- Mean Time to Detect (MTTD): Average time from incident occurrence to detection
- Mean Time to Respond (MTTR): Average time from detection to containment
- False Positive Rate: % of alerts that are false positives (goal: < 10%)
- Regulatory Compliance: % of breach notifications filed within 72-hour deadline (goal: 100%)

2024 Metrics (Year-to-Date):

- Total Incidents: 330 (up 15% from 2023)
- MTTD: 18 minutes (target: < 30 minutes) ■
- MTTR: 4.2 hours (target: < 8 hours) ■
- False Positive Rate: 12% (target: < 10%) ■■■ (improvement needed)
- Regulatory Compliance: 100% (8/8 breach notifications filed on time) ■

2025 Goals:

- Reduce false positive rate to < 10% (improve SIEM alert tuning)
- Deploy SOAR (Security Orchestration, Automation, Response) for automated containment
- Achieve MTTD < 15 minutes (from current 18 minutes)

APPENDIX A: CONTACT LIST

IRT Core Team (24/7 Availability):

Role	Name	Title	Mobile	Email	Backup
Incident Commander	Mohammed Al-Qahtani	CISO	+966-50-555-1001	mohammed.alqahtani@company.gov.sa	Nasser Al-Qahtani (CIO)
Investigation Lead	Fahad Al-Harbi	SOC Manager	+966-50-555-2001	fahad.alharbi@company.gov.sa	Khalid Al-Mutairi (SOC Analyst 1)
Technical Lead	Nasser Al-Qahtani	CIO	+966-50-555-3001	nasser.alqahtani@company.gov.sa	Ahmed Al-Dosari (IT Manager)
Privacy Officer	Fatima Al-Zahrani	CPO	+966-50-555-4001	fatima.alzahrani@company.gov.sa	Dr. Khalid Al-Mansour (DPO)
Legal Counsel	Ahmed Al-Rashid	General Counsel	+966-50-555-5001	ahmed.alrashid@company.gov.sa	Sara Al-Mutairi (Legal)
Communications Lead	Sarah Al-Mutairi	PR Manager	+966-50-555-6001	sarah.almutairi@company.gov.sa	Ahmed Al-Zahrani (Marketing)

External Contacts:

Entity	Contact	Phone	Email	Purpose
SDAIA (Data Breach)	Personal Data Protection Committee	+966-11-10093	breaches@sdaia.gov.sa	PDPL breach notification
NCA (Cyber Incident)	Cyber Security Operations Center	+966-11-274-1111	csoc@nca.gov.sa	Critical infrastructure incident
Law Enforcement	Saudi Cyber Crime Unit	1909	cybercrime@saudipolice.gov.sa	Criminal investigation
Forensic Vendor	Deloitte Cyber	+966-11-282-8400	incident.response@deloitte.com	External forensic support

APPENDIX B: INCIDENT REPORT TEMPLATE

Incident ID: INC-SEC-YYYY-####

Report Date: _____

Report Author: _____

1. Executive Summary (3-5 sentences)

Brief overview of what happened, impact, and current status.

2. Incident Details

Field	Value
Detection Date/Time	
Detection Source	(SIEM alert, user report, etc.)
Incident Category	(Malware, Intrusion, DoS, Phishing, Insider, Polic
Severity Level	(Critical, High, Medium, Low)

Impacted Systems	
Impacted Data	(if data breach)
Number of Affected Users	

3. Timeline

Time	Event	Actor
T+0:00	Initial compromise	
T+0:15	Detection (alert fired)	SOC Analyst
T+0:20	Containment initiated	
...		

4. Response Actions Taken

Describe containment, eradication, recovery steps in detail.

5. Root Cause

Why did this incident occur? What control failed?

6. Impact Assessment

- Confidentiality: Data accessed/exfiltrated? How many records?
- Integrity: Data modified or corrupted?
- Availability: Downtime? Duration?
- Financial: Estimated cost (recovery, fines, lost revenue)

7. Current Status

- Investigating
- Contained
- Eradicated
- Recovering
- Resolved
- Closed

8. Next Steps

- ☐ Action item 1
- ☐ Action item 2
- ☐ Action item 3

9. Lessons Learned (If applicable)

What went well? What could improve? Action items for future prevention.

Report Approved By:

CISO Signature: _____ Date: _____

END OF PLAN

Document Approval:

Role	Name	Signature	Date
Chief Information Security Officer (CISO)	Mohammed Al-Qahtani	[Digitally Signed]	August 1, 2024
Chief Information Officer (CIO)	Nasser Al-Qahtani	[Digitally Signed]	August 1, 2024
Chief Privacy Officer (CPO)	Fatima Al-Zahrani	[Digitally Signed]	August 1, 2024
SOC Manager	Fahad Al-Harbi	[Digitally Signed]	August 1, 2024

Official Seal: Company A - Riyadh, Kingdom of Saudi Arabia

Distribution:

- Incident Response Team (all 12 members)
- IT Security Team
- IT Operations Team
- Executive Leadership (CEO, CIO, CISO, CPO)
- Audit & Compliance Team

Related Documents:

- Data Security Strategy 2025-2027 v2.0
- Access Control Policy v4.2
- Data Breach Notification Procedure v2.7
- Business Continuity Plan v2.3
- Data Classification Framework v3.5

